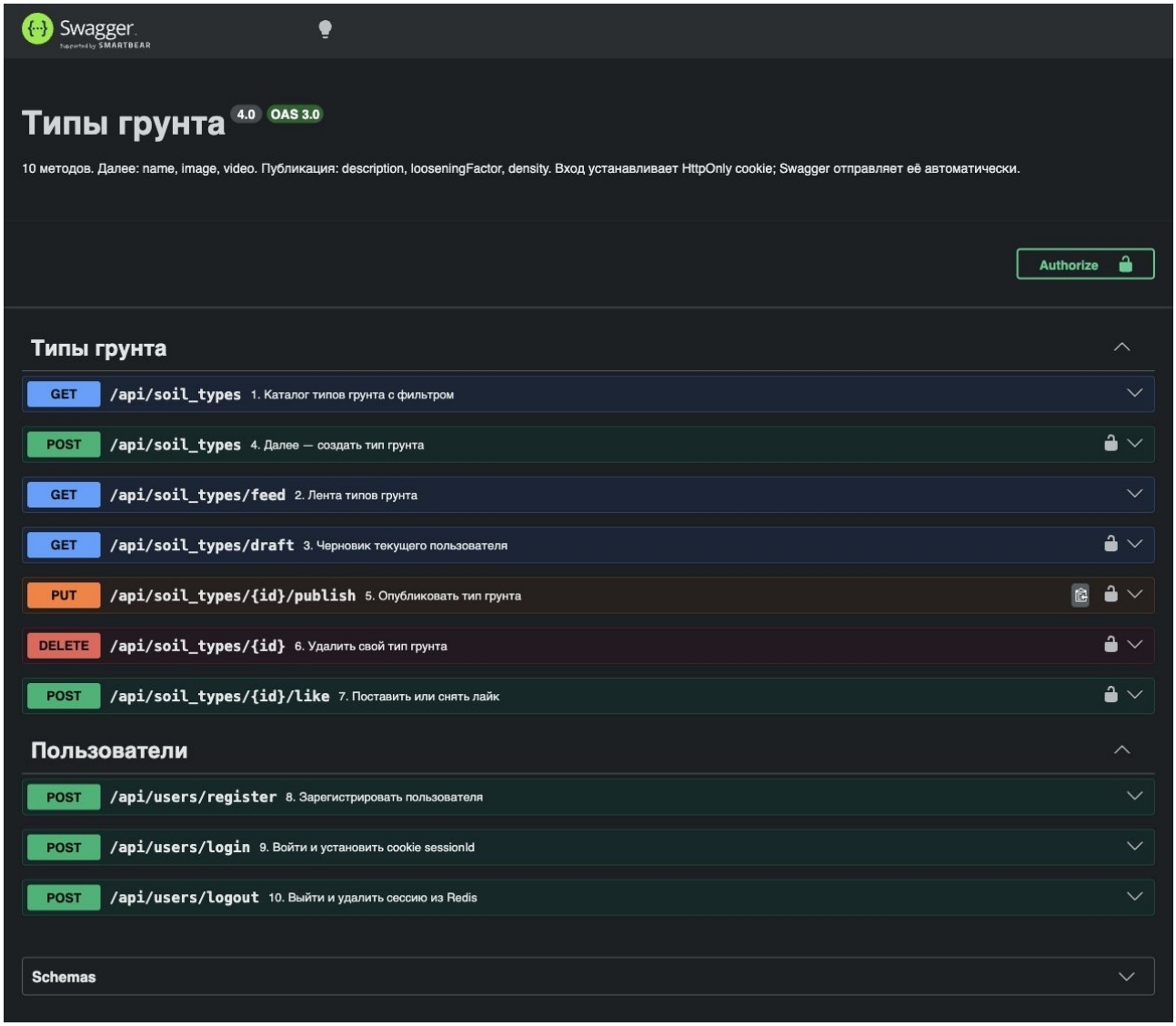
Лабораторная работа 4 Авторизация и Swagger

Давыдов Кирилл Игоревич, ИУ5-54Б

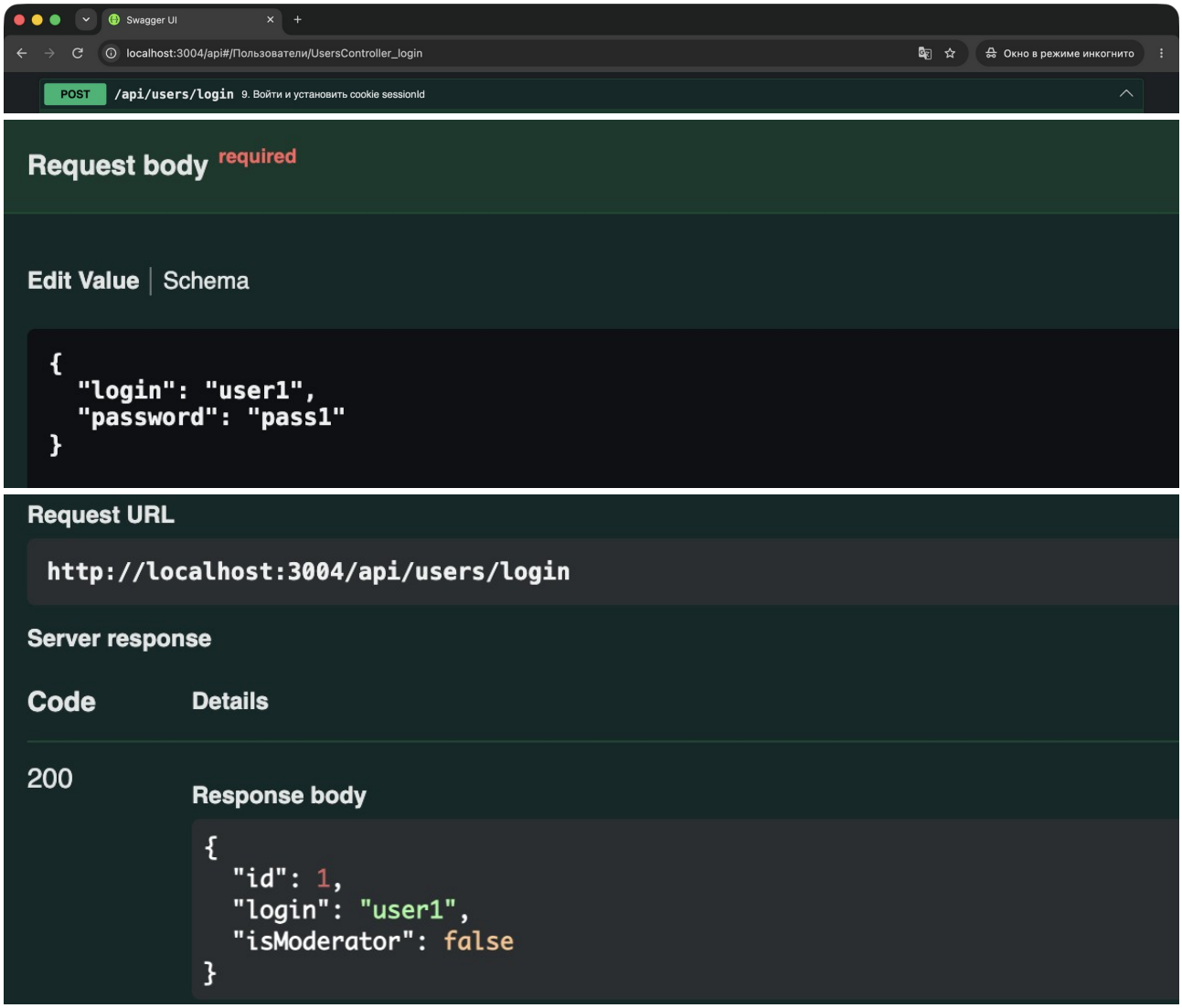
Тема — определение объёма земляных работ при разработке котлована

Реализованы регистрация, вход и выход с серверными сессиями Redis и HttpOnly cookie. TypeORM сохранён. Каталог и лента доступны гостю; свой черновик, создание, публикация, лайки и удаление требуют входа. API содержит ровно десять операций.



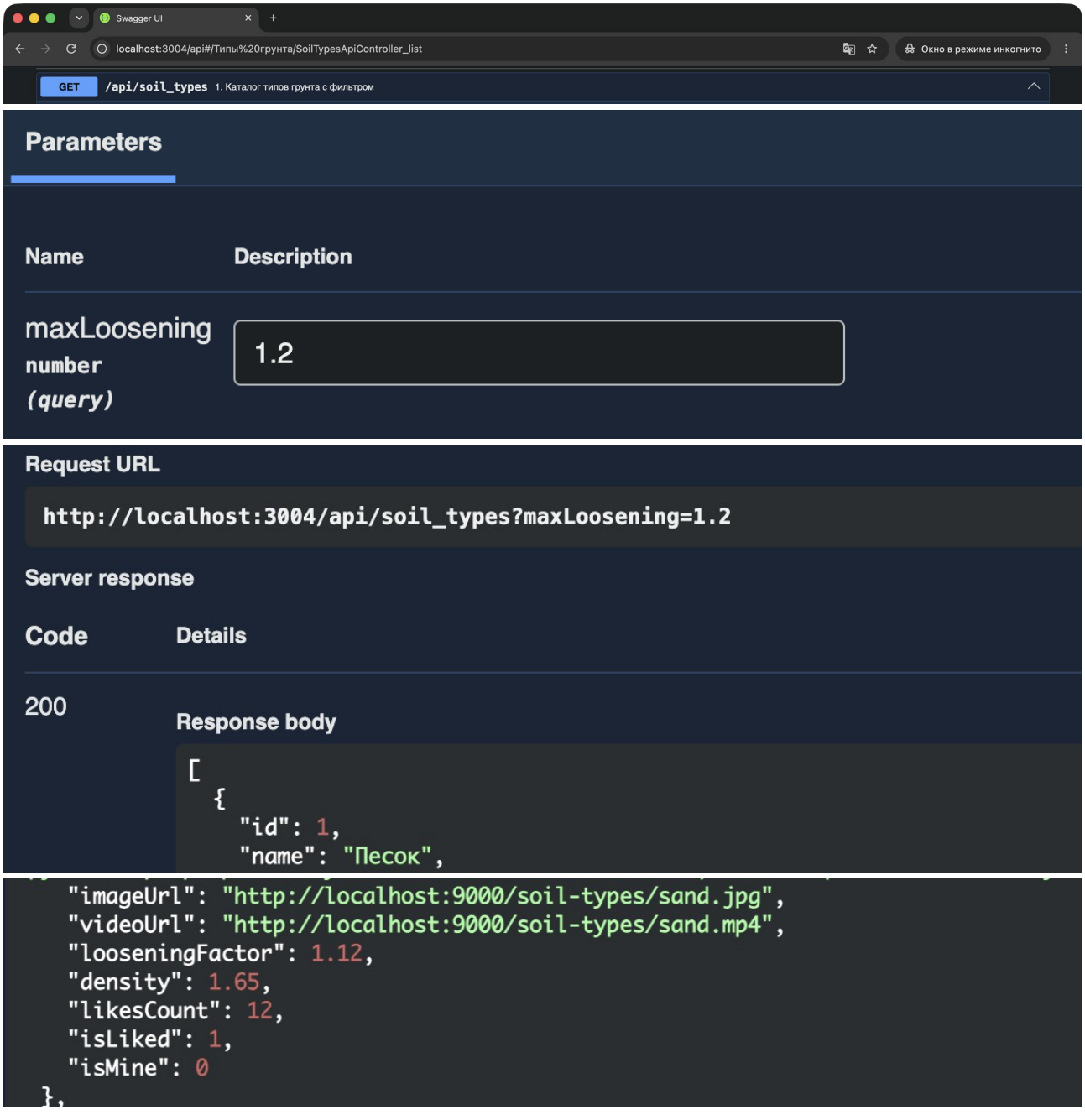
Скриншот 1 Вход через Swagger

В приватном окне Chrome выполнен POST /api/users/login. Входные поля login и password видны в Request body. Ответ 200 содержит пользователя без пароля; браузер сохраняет sessionId.



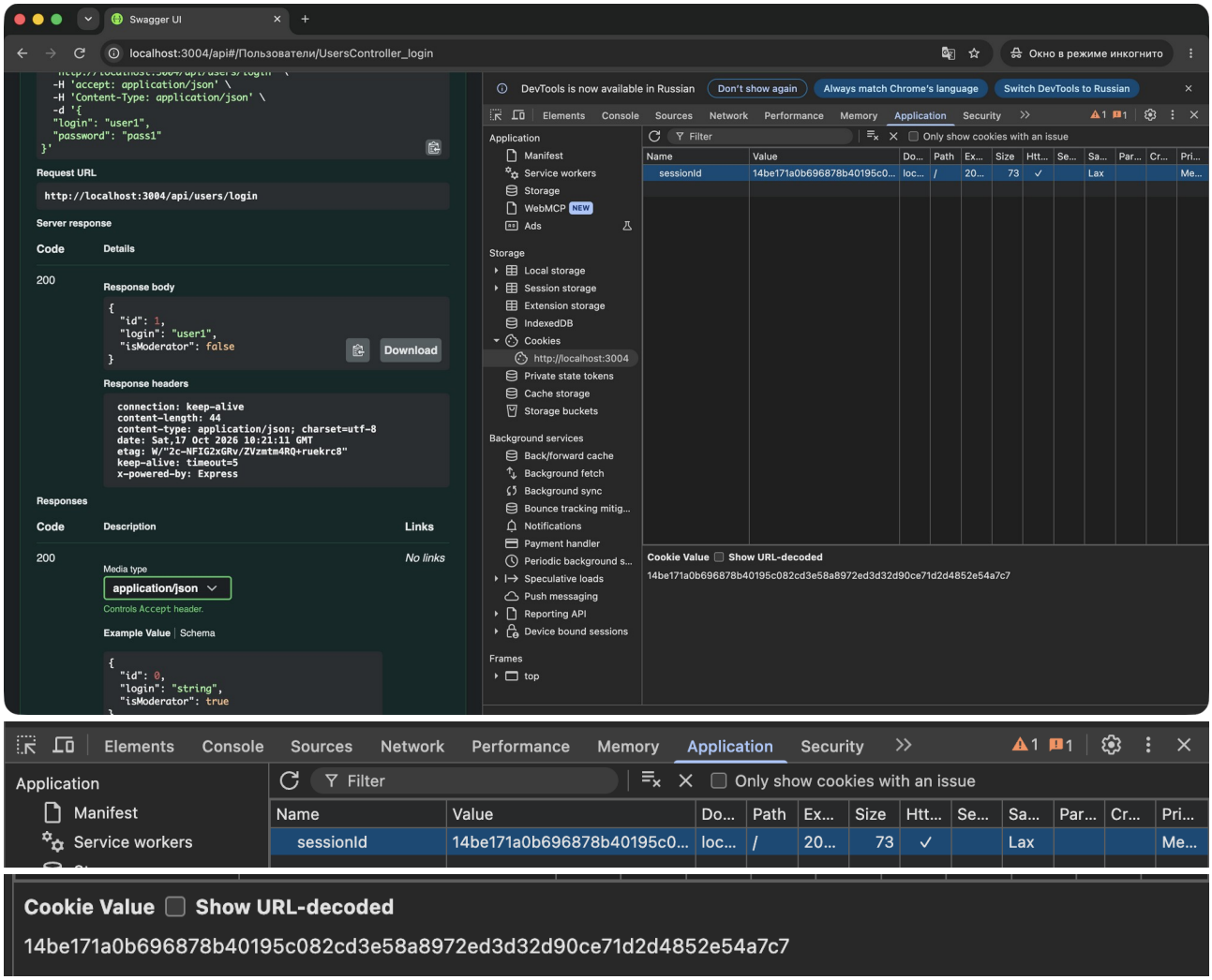
Скриншот 2 Каталог после входа

В том же приватном окне выполнен GET /api/soil_types с maxLoosening=1.2. Cookie передаётся браузером автоматически. Показаны параметры и фрагменты фактического ответа 200: у песка isLiked=1, isMine=0.



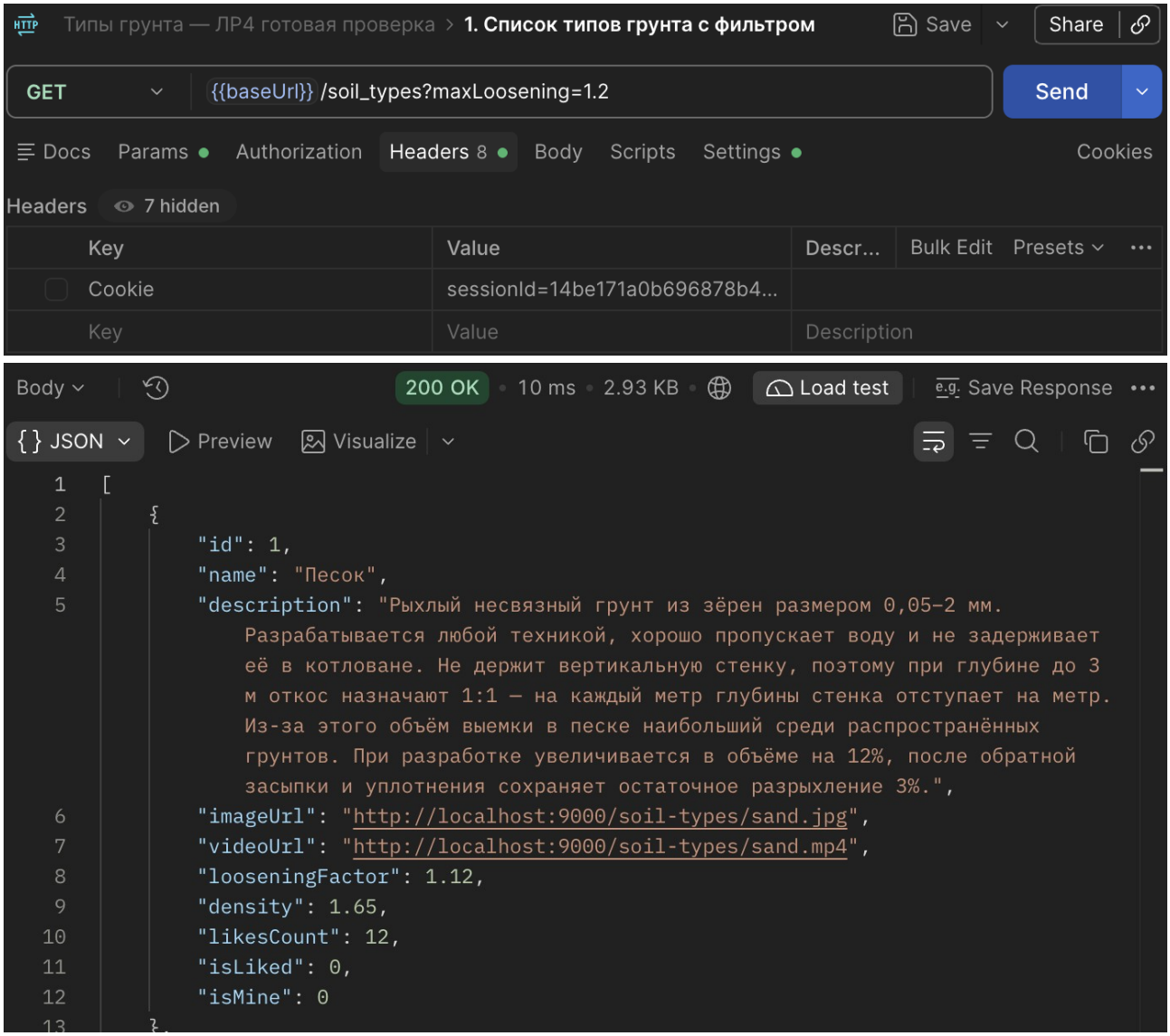
Скриншот 3 Cookie в браузере

В Chrome DevTools открыта Application → Cookies → localhost:3004. Видны sessionId, HttpOnly и SameSite=Lax. В нижней панели показано полное значение, перенесённое в заголовок Cookie в Postman. Cookie содержит только случайный идентификатор.



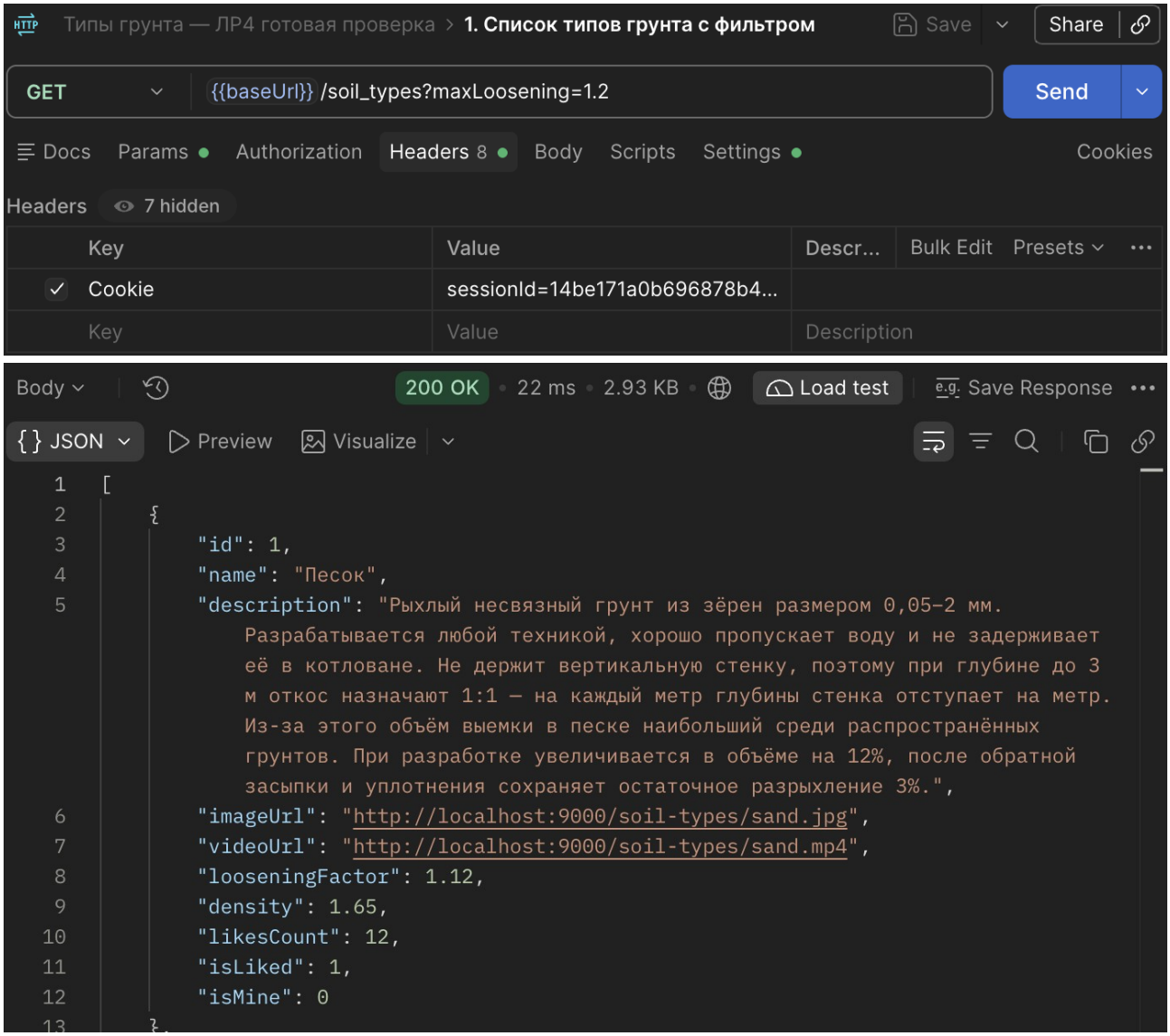
Скриншот 4 Каталог без cookie

В Postman у заголовка Cookie снята галочка, Cookie Jar отключён. GET с фильтром возвращает 200. У гостя isLiked=0 и isMine=0. Входные данные находятся в URL, ответ показан отдельно.



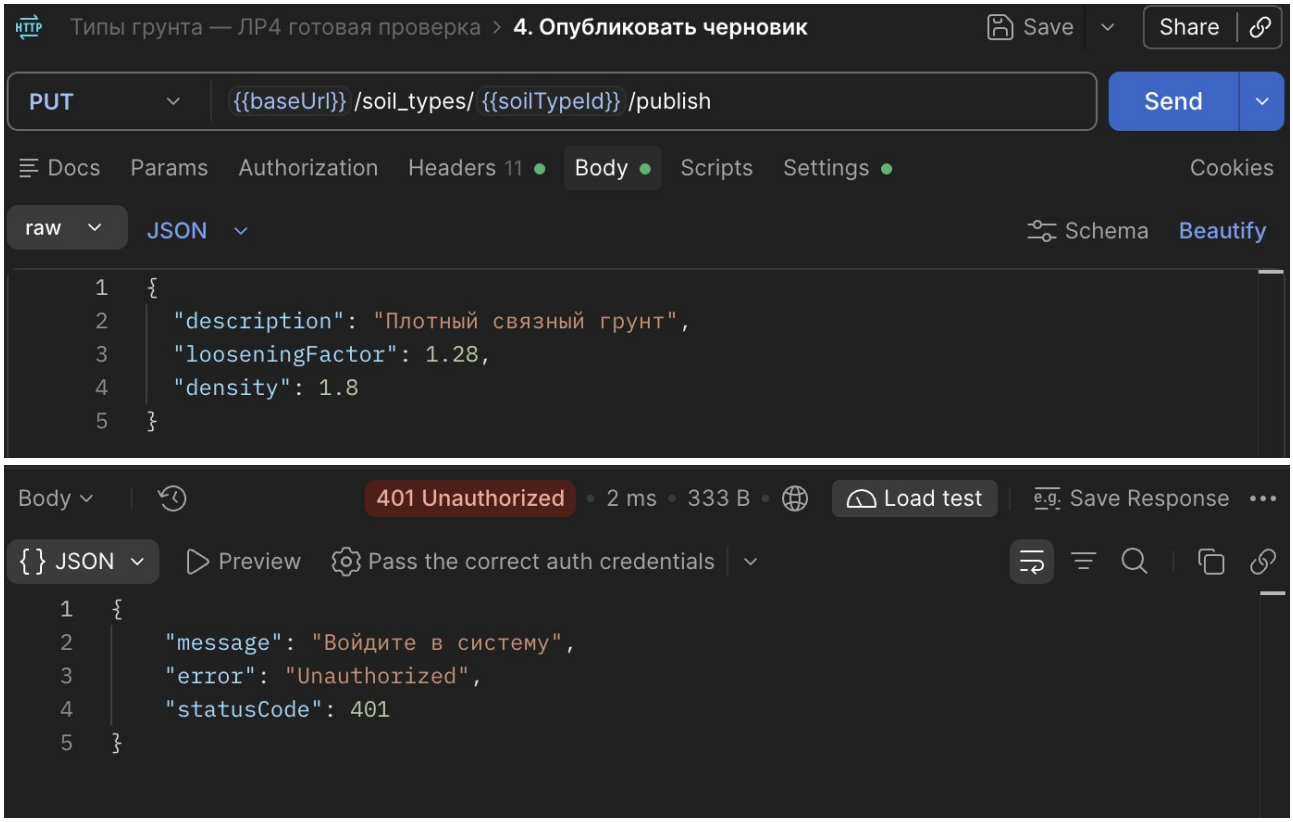
Скриншот 5 Каталог с cookie

В Postman включён заголовок Cookie: sessionId со значением из Chrome. Тот же GET возвращает 200. Для пользователя 1 у песка isLiked=1, isMine=0, поскольку карточка принадлежит пользователю 2.



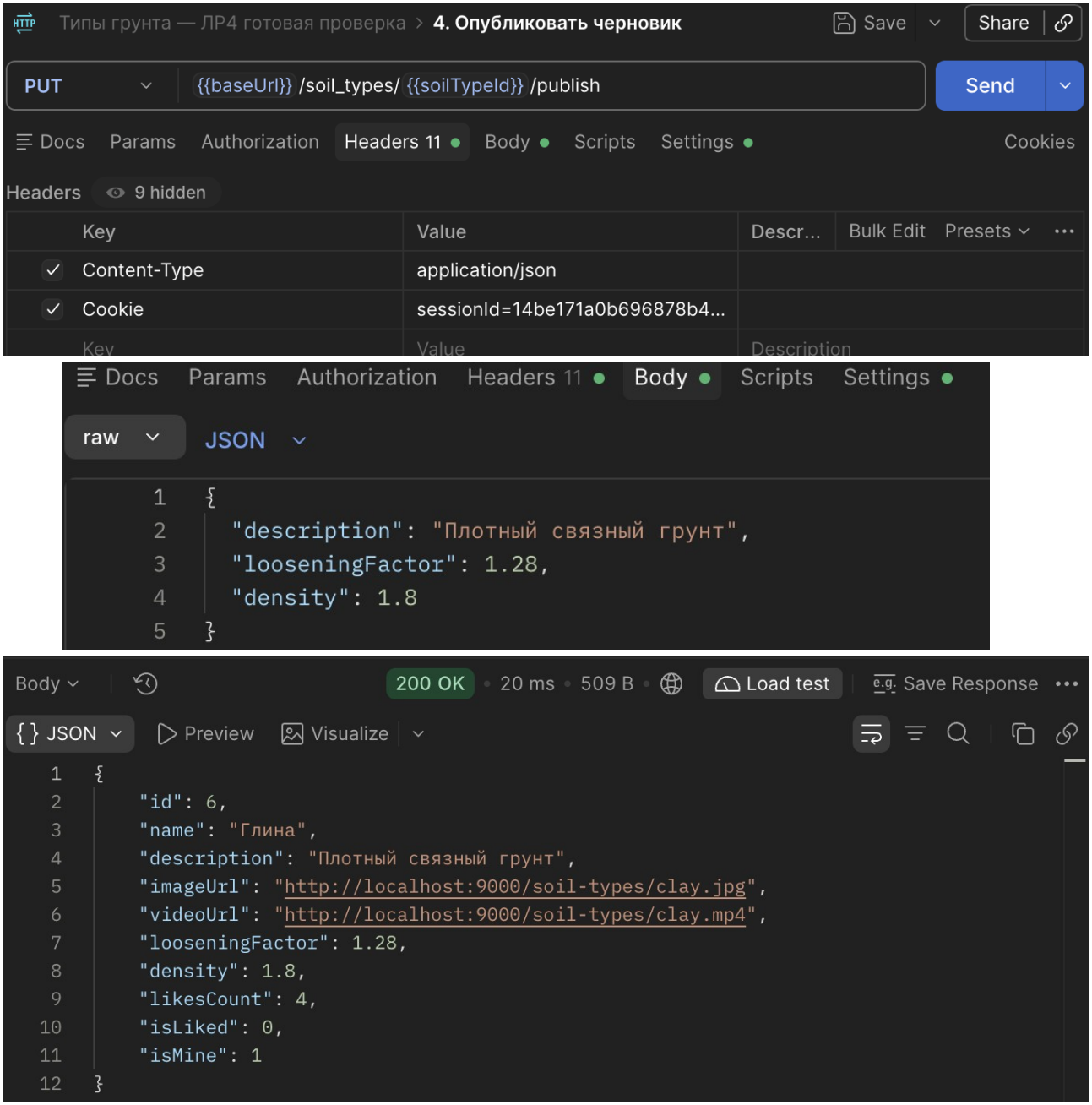
Скриншот 6 Публикация без входа

PUT /api/soil_types/6/publish без cookie возвращает 401. В Body показаны ровно три входных поля: description, looseningFactor, density. Карточка в БД не изменяется.



Скриншот 7 Публикация владельцем

Для того же PUT и того же тела включён заголовок Cookie владельца. Получен 200: опубликована Глина с id=6, isMine=1. Дата и статус устанавливаются сервером и не передаются во входных полях.



Скриншот 8 Сессия в Redis

Фактический вывод redis-cli для sessionId из Chrome и Postman: GET возвращает userId=1, TTL — оставшиеся секунды до истечения часа. Удаление ключа после выхода проверено отдельным HTTP-сценарием.

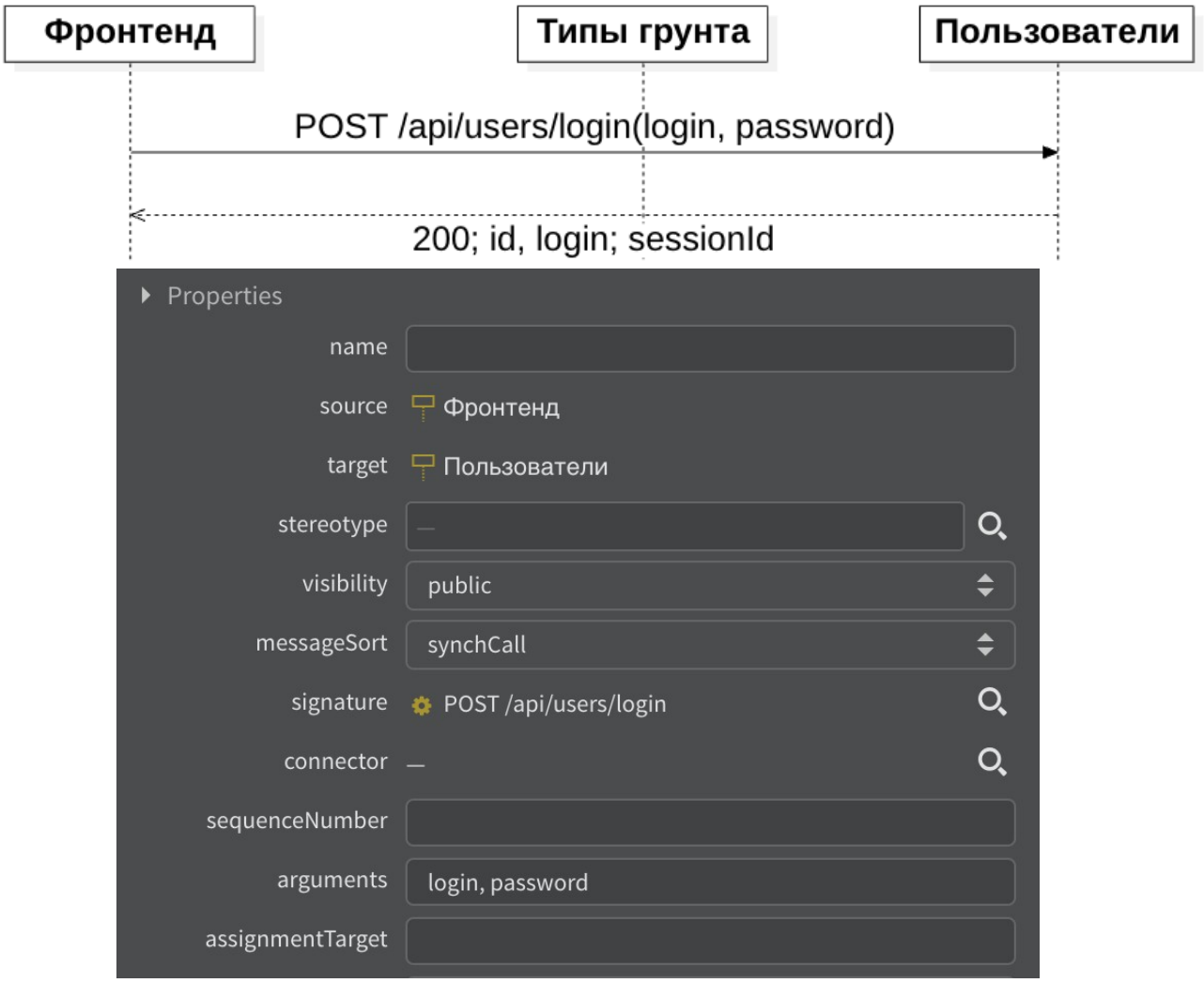
Redis — userId и TTL сессии браузера

```
redis-cli GET session:14be171a0b696878b40195c082cd3e58a8972ed3d32d90ce71d2d4852e54a7c7
1

redis-cli TTL session:14be171a0b696878b40195c082cd3e58a8972ed3d32d90ce71d2d4852e54a7c7
2278
```

Скриншот 9 Связь signature

В StarUML выбран запрос входа. В Property Editor target указывает на линию жизни «Пользователи», signature — на существующую операцию POST /api/users/login. На диаграмме ровно три линии жизни. Аналогичные ссылки заданы у всех восьми запросов.



Проверка реализации

Выполнены 38 проверок HTTP API на отдельной БД: публичное чтение; защита всех изменений; неверный пароль; вход двух пользователей и изоляция черновиков; загрузка файлов в MinIO; запрет второго черновика; публикация только своего; установка и снятие лайка; запрет удаления чужого; регистрация; удаление сессии при выходе. Схема Swagger содержит десять операций и три поля создания. Сборка NestJS завершается успешно.

Проверка	**Результат**
Каталог гостя	200; isMine=0, isLiked=0
Черновик, создание, публикация, лайк, удаление гостем	401
Неверный пароль	401
Чужой черновик	404 при публикации
Удаление чужой карточки	403
Лишнее поле creatorId	400
Повторный лайк	Количество не увеличивается
После выхода старая cookie	401 на защищённом методе
Файлы из MinIO	Оба URL возвращают 200

Исходная база RIP не использовалась для изменений. Проверки ЛР4 выполнены на rip_lab4_20261017 и порту 3004, ЛР3 — на rip_lab3_20261017 и порту 3003. Для обычного запуска приложение использует настройки .env и порт 3000. Контрольные вопросы — learn/12-kontrolnye-lr4.md; ТЗ и таблица методов — РПЗ_ЛР4.docx.